

MediAssist

A role-based-access-control medical chatbot built on a hybrid retrieval RAG pipeline – verifiable reasoning, a live LLM-as-judge, and a rebuild driven by a full security & architecture audit.

88,195

CHUNKS INDEXED IN PINECONE

3

RBAC ROLES – DOCTOR / NURSE / ADMIN

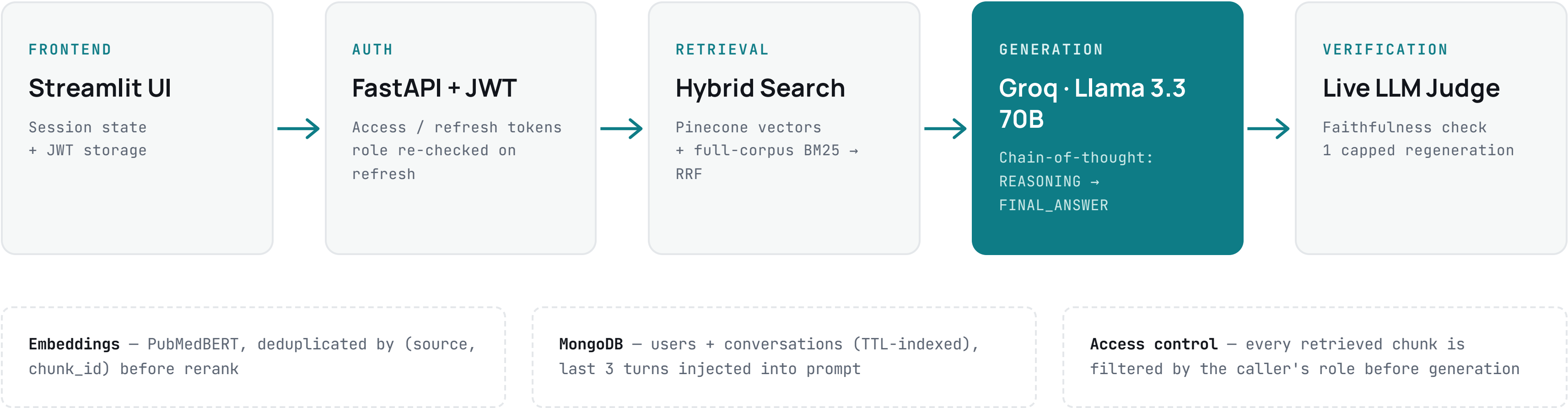
14

AUDIT-DRIVEN ARCHITECTURE REVISIONS

Stack – FastAPI · Streamlit · Pinecone · Groq / Llama 3.3 70B · MongoDB · Docker · Render

Request lifecycle

Five stages between a clinician’s question and a verified answer — every stage below is a real module in the codebase, not a simplification.



Four decisions that shaped the system

01

Hybrid retrieval, not vector-only

Full-corpus BM25 reranking fused with Pinecone vector search using true `Reciprocal Rank Fusion` — not a min-max weighted blend of two incompatible score scales.

02

Reasoning as an inspectable artifact

The model is required to emit explicit `###REASONING###` and `###FINAL_ANSWER###` markers, so clinicians can audit how an answer was reached, not just read the answer.

03

Self-checking before a response ships

A live LLM-as-judge scores every medical answer for faithfulness against retrieved context and triggers exactly one capped regeneration if it fails — wired inline, not run as an offline batch job.

04

Engineered for a free-tier budget

One shared Groq client, a bounded LRU + 7-day TTL expansion cache, and conversation history capped at 3 turns keep every request inside free-tier API and DB quotas.

Built to fail safely

ROLE-BASED ACCESS, ENFORCED AT RETRIEVAL

ROLE	RETRIEVED CONTENT
Doctor	Full clinical corpus, incl. nurse- and doctor-tagged documents
Nurse	Nurse-tagged documents only – enforced by one shared ROLE_ACCESS map
Admin	Upload & index management, no clinical-answer generation

HARDENING FROM THE AUDIT TRAIL

- AUTH

JWT access + refresh tokens; **role is re-verified against the database** on every refresh instead of trusting a stale claim.
- UPLOAD

Path-traversal fix on the document upload endpoint.
- SECRETS

An exposed API key was rotated and **scrubbed from git history** with `git filter-repo`.
- CI/CD

GitHub Actions gate: **lint** → **tests** → **Docker build check** → **deploy** – a failing pipeline can never reach Render.

Built with

INTERFACE & API	RETRIEVAL & GENERATION	DATA & DELIVERY
Streamlit frontend	Pinecone + PubMedBERT vector search	MongoDB Atlas users, conversations
FastAPI JWT-secured backend	BM25 → RRF hybrid rerank	Docker + Render two-service deploy
	Groq · Llama 3.3 70B generation + live judge	GitHub Actions CI/CD gate

Full source, the audit history, and deployment configs are in the repository.

github.com/anitkumarmaity1-hash/medical-assistant